

FACULDADE DE TECNOLOGIA DE BARUERI – FATEC BARUERI

Curso de Gestão de Tecnologia da Informação (GTI)

**GESTÃO DE IDENTIDADE, ACESSOS E SEGURANÇA DA
INFORMAÇÃO NA FATEC BARUERI À LUZ DO COBIT:
APLICAÇÃO DOS PROCESSOS EDM01 E APO01**

Henrique Moura

João Victor

Lucas Rafael

Melissa Victória

Pedro Henrique

Barueri – SP

2026

FACULDADE DE TECNOLOGIA DE BARUERI – FATEC BARUERI

Curso de Gestão de Tecnologia da Informação (GTI)

**GESTÃO DE IDENTIDADE, ACESSOS E SEGURANÇA DA
INFORMAÇÃO NA FATEC BARUERI À LUZ DO COBIT:
APLICAÇÃO DOS PROCESSOS EDM01 E APO01**

Trabalho apresentado à disciplina de Gestão de TI, ministrada pelo Professor Vander Ribeiro, do curso de Gestão de Tecnologia da Informação da Fatec Barueri, como requisito parcial para obtenção de nota.

Professor: Vander Ribeiro

Barueri – SP

2026

SUMÁRIO

SUMÁRIO	2
1. INTRODUÇÃO	3
2. REFERENCIAL TEÓRICO	5
2.1 O framework COBIT	6
2.2 EDM01 – Ensured Governance Framework Setting and Maintenance	6
2.3 APO01 – Managed IT Management Framework	6
2.4 Relação entre EDM01 e APO01 no contexto deste trabalho	6
3. DIAGNÓSTICO DO CENÁRIO ATUAL DA FATEC BARUERI (AS-IS)	7
3.1 Identificação de stakeholders	8
3.2 Levantamento de regimentos e portarias	8
3.3 Mapeamento de restrições e leis aplicáveis	8
3.4 Principais fragilidades observadas	8
4. FICHA DE IMPLANTAÇÃO DO EDM01	9
4.1 Etapa 1 – Mapeamento do Cenário Atual (As-Is)	10
4.2 Etapa 2 – Definição da Estrutura de Governança	10
4.3 Etapa 3 – Formalização de Políticas e Diretrizes de Governança	10
4.4 Etapa 4 – Monitoramento e Avaliação Contínua da Governança	11
5. FICHA DE GESTÃO DO APO01	11
5.1 Processos de Gestão	12
5.2 Estruturas Organizacionais (papéis e responsabilidades)	12
5.3 Atividades Confiáveis e Repetíveis	12
5.4 Itens de Informação (documentação)	13
5.5 Políticas e Procedimentos	13
5.6 Habilidades e Competências	13
6. REGRAS PROPOSTAS DE GESTÃO DE ACESSOS E SEGURANÇA	14
6.1 Regras de ciclo de vida de identidade	15
6.2 Regras de controle de acesso	15
6.3 Regras de autenticação e senha	15
6.4 Regras de auditoria e resposta a incidentes	15
7. CONCLUSÃO	16
REFERÊNCIAS	17

1. INTRODUÇÃO

O COBIT (Control Objectives for Information and Related Technologies) é um framework internacionalmente reconhecido para governança e gestão de TI corporativa, mantido pela ISACA. Ele organiza a atuação da tecnologia da informação em duas grandes dimensões complementares: a Governança, representada pelos processos do domínio EDM (Evaluate, Direct and Monitor), voltada à definição de diretrizes, avaliação de desempenho e supervisão exercida pela alta administração e a Gestão, representada pelos domínios APO, BAI, DSS e MEA, responsável por planejar, construir, executar e monitorar as atividades de TI no dia a dia da organização.

Este trabalho tem como objetivo aplicar dois processos centrais do COBIT o EDM01 (Ensured Governance Framework Setting and Maintenance) e o APO01 (Managed IT Management Framework) a um cenário real e concreto: a gestão de identidade, o controle de acessos e a segurança da informação nos laboratórios de informática e nos sistemas acadêmicos da Fatec Barueri.

O tema foi escolhido por sua relevância prática. Os laboratórios de uma instituição de ensino como a Fatec reúnem características que os tornam ambientes de risco elevado do ponto de vista de segurança da informação: máquinas compartilhadas por dezenas de alunos ao longo do dia, uso frequente de credenciais genéricas ou compartilhadas, alta rotatividade de usuários (ingressantes, formandos, trancamentos de matrícula) e integração entre o sistema acadêmico (SIGA) e o ambiente de autenticação institucional (Active Directory / Entra ID). Sem uma governança e uma gestão de acessos bem definidas, esse cenário favorece contas órfãs, compartilhamento indevido de senhas, dificuldade de rastreabilidade em incidentes de segurança e exposição a normas como a LGPD.

Assim, o presente trabalho busca responder a duas perguntas centrais: (i) como a Fatec Barueri deveria estruturar a governança da sua área de TI para que decisões sobre segurança e acesso sejam tomadas de forma legítima e alinhada aos objetivos institucionais (EDM01); e (ii) como o framework de gestão de TI deveria ser organizado na prática, definindo processos, papéis, políticas e competências, para que a gestão de identidade e acessos funcione de forma confiável e repetível (APO01).

O trabalho está estruturado da seguinte forma: a seção 2 apresenta um breve referencial teórico sobre o COBIT e os dois processos escolhidos; a seção 3 traz o diagnóstico do cenário atual (As-Is) da Fatec Barueri; a seção 4 desenvolve a ficha de implantação do EDM01; a seção 5 desenvolve a ficha de gestão do APO01; a seção 6 consolida um conjunto de regras práticas de gestão de acessos e segurança propostas a partir da aplicação dos dois processos; e a seção 7 apresenta a conclusão do trabalho.

2. REFERENCIAL TEÓRICO

2.1 O framework COBIT

O COBIT organiza a TI corporativa em 40 processos, divididos entre Governança (5 processos do domínio EDM) e Gestão (35 processos distribuídos nos domínios APO – Align, Plan and Organize; BAI – Build, Acquire and Implement; DSS – Deliver, Service and Support; e MEA (Monitor, Evaluate and Assess). Cada processo é descrito, no modelo de referência do COBIT, por meio de sete categorias de habilitadores (enablers): Processos, Estruturas Organizacionais, Princípios e Políticas, Informação, Cultura e Comportamento, Serviços/Infraestrutura/Aplicativos, e Pessoas/Habilidades/Competências. É esse mesmo modelo de habilitadores que estrutura as fichas apresentadas neste trabalho, no formato solicitado em sala de aula: Processos de Gestão, Estruturas Organizacionais, Atividades Confiáveis e Repetíveis, Itens de Informação, Políticas e Procedimentos, e Habilidades e Competências.

2.2 EDM01 – Ensured Governance Framework Setting and Maintenance

O EDM01 é o primeiro e mais fundamental processo de governança do COBIT. Seu propósito é analisar e articular os requisitos para a governança de TI da organização, estabelecendo e mantendo estruturas de governança eficazes, os princípios de tomada de decisão, papéis, responsabilidades, atividades e prazos de forma alinhada aos objetivos e à estratégia institucional. Em outras palavras, o EDM01 define o "quem decide o quê" antes que qualquer processo de gestão possa funcionar de forma legítima e sustentável.

2.3 APO01 – Managed IT Management Framework

O APO01 é o processo de gestão que operacionaliza a governança definida pelo EDM01. Seu objetivo é implementar uma estrutura de gestão consistente para as necessidades de TI da organização, incluindo estruturas organizacionais habilitadoras, políticas e práticas de gestão, e um ambiente propício para a sua aplicação. É o APO01 que transforma diretrizes de alto nível em processos operacionais concretos papéis definidos, políticas escritas, atividades recorrentes e documentação que sustentam, neste trabalho, a gestão diária de identidade, acessos e segurança.

2.4 Relação entre EDM01 e APO01 no contexto deste trabalho

EDM01 e APO01 não são processos independentes: o COBIT os concebe como duas faces de um mesmo ciclo. O EDM01 avalia (Evaluate) o contexto institucional, direciona (Direct) por meio de diretrizes formais e monitora (Monitor) se a governança está sendo cumprida. O APO01, por sua vez, recebe essas diretrizes e as materializa em processos, estruturas organizacionais, políticas, documentação e competências. Neste trabalho, isso significa que a decisão de "como a Fatec Barueri vai tratar segurança e acesso" nasce no EDM01 por meio do Comitê de Segurança da Informação e TI e é executada no dia a dia pelas rotinas descritas no APO01, como a revisão trimestral de acessos e a gestão do ciclo de vida de identidades.

Essa relação de dependência é importante para o diagnóstico apresentado na seção seguinte: muitas das fragilidades observadas hoje na Fatec Barueri (contas compartilhadas, ausência de revisão de privilégios) não decorrem apenas de uma falha operacional isolada, mas da ausência de uma governança explícita que definisse, antes de tudo, quem deveria ter autoridade para exigir essas práticas.

3. DIAGNÓSTICO DO CENÁRIO ATUAL DA FATEC BARUERI (AS-IS)

Antes de propor qualquer estrutura de governança ou gestão, é necessário levantar como a tomada de decisão em TI e a gestão de acessos ocorrem hoje na Fatec Barueri. Esse levantamento corresponde ao primeiro passo do próprio EDM01 e serve de base tanto para a ficha de governança quanto para a ficha de gestão apresentadas nas seções seguintes.

3.1 Identificação de stakeholders

Foram identificados como principais interessados na governança de TI da instituição: a Direção da Fatec Barueri, a Congregação (órgão colegiado da unidade), os Coordenadores de curso, a equipe de TI local do câmpus e o Centro Paula Sousa (CPS), mantenedor central que define diretrizes aplicáveis a todas as unidades da rede Fatec.

3.2 Levantamento de regimentos e portarias

Foram mapeados os documentos institucionais que hoje conferem poder de decisão sobre TI, como o Regimento Interno da unidade e portarias do CPS relacionadas a segurança da informação e uso de laboratórios. Constatou-se que, embora existam normas gerais de uso dos laboratórios, não há um documento único e atualizado que trate especificamente da gestão do ciclo de vida de identidades e do controle de acessos privilegiados.

3.3 Mapeamento de restrições e leis aplicáveis

- Lei Geral de Proteção de Dados (LGPD – Lei nº 13.709/2018): aplicável ao tratamento de dados pessoais de alunos e professores nos sistemas acadêmicos e no Active Directory.
- Lei de Acesso à Informação (LAI – Lei nº 12.527/2011): aplicável por se tratar de instituição pública, impondo transparência sobre determinados processos administrativos.
- Estatuto do Centro Paula Sousa: define a estrutura de governança à qual as unidades de ensino, incluindo a Fatec Barueri, estão subordinadas.
- Normas de licitação e contratação pública: aplicáveis a eventuais aquisições de soluções de IAM (Identity and Access Management) ou de infraestrutura de diretório.

3.4 Principais fragilidades observadas

- Uso recorrente de credenciais compartilhadas entre alunos nos laboratórios, dificultando a rastreabilidade de ações individuais.
- Ausência de um fluxo formal e automatizado de desligamento de contas quando um aluno se forma, tranca a matrícula ou é desligado, gerando risco de contas órfãs.
- Falta de revisão periódica documentada dos privilégios administrativos concedidos no Active Directory.
- Inexistência de um comitê formal que centralize decisões sobre segurança da informação e controle de acesso.

4. FICHA DE IMPLANTAÇÃO DO EDM01

Esta seção apresenta a proposta de implantação do processo EDM01 na Fatec Barueri, com foco na governança da segurança da informação e da gestão de acessos. A implantação foi dividida em quatro etapas, descritas a seguir.

4.1 Etapa 1 – Mapeamento do Cenário Atual (As-Is)

Antes de documentar qualquer estrutura de governança, é necessário levantar como a tomada de decisão em TI acontece hoje na instituição. Esta etapa foi detalhada na seção 3 deste trabalho e envolveu:

- **Identificação de stakeholders:** mapear quem tem autoridade sobre decisões de TI (Direção, Congregação, Coordenadores, TI local e Centro Paula Sousa).
- **Levantamento de regimentos e portarias:** identificar quais documentos já existem que dão poderes de decisão à TI.
- **Mapeamento de restrições e leis:** mapear normas externas aplicáveis (LAI, LGPD, estatuto do CPS, normas de licitação).

4.2 Etapa 2 – Definição da Estrutura de Governança

Com o cenário atual mapeado, a segunda etapa consiste em desenhar a estrutura formal de governança da segurança da informação, definindo quem decide, quem avalia e quem monitora:

- **Criação do Comitê de Segurança da Informação e TI:** grupo colegiado, com representantes da Direção, da Coordenação de TI e de um docente da área de segurança, responsável por aprovar diretrizes, avaliar riscos e validar exceções.
- **Definição de papéis de decisão (accountability):** estabelecer explicitamente quem aprova a criação de contas privilegiadas, quem autoriza exceções de acesso e quem responde perante o Centro Paula Sousa por incidentes de segurança.
- **Alinhamento com a estratégia institucional:** garantir que as decisões de segurança e acesso estejam conectadas aos objetivos pedagógicos e administrativos da Fatec, e não apenas a critérios técnicos isolados.

4.3 Etapa 3 – Formalização de Políticas e Diretrizes de Governança

A terceira etapa transforma as decisões da estrutura de governança em documentos formais, aprovados pelo Comitê e publicados para toda a comunidade acadêmica:

- **Política de Governança de Segurança da Informação:** documento-guarda-chuva que estabelece princípios gerais (menor privilégio, necessidade de saber, responsabilização individual) a serem seguidos por todos os processos de gestão subordinados, incluindo o APO01.
- **Diretrizes de conformidade legal:** orientações formais sobre como a instituição atende à LGPD e à LAI no tratamento de dados de identidade e acesso.
- **Calendário de revisão da governança:** definição de prazos (por exemplo, revisão anual) para que a própria estrutura de governança seja reavaliada frente a mudanças legais ou institucionais.

4.4 Etapa 4 – Monitoramento e Avaliação Contínua da Governança

Por fim, a quarta etapa garante que a governança implantada não seja estática, fechando o ciclo Evaluate–Direct–Monitor do EDM01:

- **Indicadores de governança:** acompanhamento periódico pelo Comitê de indicadores como número de incidentes de acesso, tempo médio de revogação de contas e percentual de políticas atualizadas.
- **Prestação de contas ao Centro Paula Sousa:** envio de relatórios periódicos que demonstrem que a governança local está alinhada às diretrizes centrais do CPS.
- **Ciclo de melhoria contínua:** revisão da estrutura de governança sempre que auditorias, incidentes ou mudanças legais indicarem necessidade de ajuste.

5. FICHA DE GESTÃO DO APO01

Enquanto o EDM01 definiu quem decide e por quê, o APO01 detalha como a gestão de identidade, acessos e segurança deve funcionar no dia a dia da Fatec Barueri. A ficha a seguir segue o mesmo modelo de habilitadores utilizado em sala de aula, aplicado ao projeto "Implantação de Gestão de Identidade e Segurança", com foco no COBIT.

5.1 Processos de Gestão

Definem o "como" as coisas acontecem no ciclo de vida de acessos e segurança.

- **Gestão do Ciclo de Vida de Identidades (relacionado a APO13 / DSS05):** fluxo desde a validação da matrícula do aluno ou a contratação do professor no sistema acadêmico (SIGA) até a atribuição automática dos papéis de acesso (RBAC) e a sincronização com o ambiente de autenticação (Active Directory / Entra ID).
- **Revogação de Acessos:** regras para desativação imediata de contas de alunos egressos, jubilados ou desligados, evitando contas órfãs no sistema.

5.2 Estruturas Organizacionais (papéis e responsabilidades)

Definem quem decide, quem audita e quem executa no dia a dia.

- **Comitê de Segurança da Informação e TI da Fatec:** define diretrizes de controle de acesso, aprova exceções de segurança e valida mudanças nas políticas do Active Directory (papel herdado da estrutura de governança do EDM01).
- **Gestor de Segurança da Informação (encarregado de TI):** responsável por garantir o alinhamento das políticas da faculdade com o COBIT e com a LGPD.
- **Administrador de Identidade e Acessos (IAM Admin):** responsável técnico pela manutenção da infraestrutura de diretório, pelo controle de privilégios mínimos e pela gestão dos privilégios de Administrador de Domínio.
- **Equipe de Suporte e Helpdesk (Nível 1/2):** responsável pela validação de identidade em solicitações presenciais de reset de senha e pela liberação de múltiplos fatores de autenticação (MFA).

5.3 Atividades Confiáveis e Repetíveis

Rotinas operacionais padronizadas para garantir resiliência e possibilidade de auditoria.

- **Auditoria e Revisão Periódica de Acessos:** revisão trimestral das contas com privilégios elevados (Domain Admins, Schema Admins) e das permissões de acesso às pastas de rede e laboratórios.
- **Monitoramento e Resposta a Incidentes de Identidade:** coleta contínua e análise de logs do AD/SIEM para identificar tentativas de ataque por força bruta, acessos simultâneos suspeitos ou elevação indevida de privilégio.
- **Backup Active Directory:** execução de scripts de backup diário do System State, garantindo recuperação em caso de falha ou incidente.
- **Monitoramento de Logs de DNS:** revisão semanal dos logs de erro do DNS para identificar tentativas de ataque ou falhas de resolução de nomes.

5.4 Itens de Informação (documentação)

- **Topologia de Rede:** mapa lógico mostrando onde os servidores de DNS/DHCP estão localizados.
- **Dicionário de Atributos:** definição do que cada campo do Active Directory deve conter por exemplo, o campo "Descrição" deve trazer o RA (Registro Acadêmico) do aluno.

5.5 Políticas e Procedimentos

- **Política de Complexidade de Senhas:** definida via GPO (Group Policy Object), estabelecendo tamanho mínimo e uso de caracteres especiais.
- **Procedimento de Desligamento:** definição clara do que acontece com a conta do aluno no Active Directory quando ele se forma ou tranca a matrícula, integrado à Gestão do Ciclo de Vida de Identidades.

5.6 Habilidades e Competências

- **Treinamento Interno:** capacitação da equipe técnica em administração de servidores Windows Server e em conceitos de redes TCP/IP, especialmente sub-redes e DHCP.
- **Conscientização de Segurança:** campanhas para incentivar professores e alunos a não compartilharem senhas do Active Directory e a bloquearem a estação de trabalho (Win+L) ao sair do laboratório.

- **Infraestrutura de Servidor:** manutenção do sistema operacional onde residem o AD/DNS sempre atualizado, com serviços desnecessários desativados.
- **Alta Disponibilidade:** manutenção de pelo menos dois Controladores de Domínio (DCs), garantindo que, em caso de falha de um deles, o login e o DNS continuem funcionando.

6. REGRAS PROPOSTAS DE GESTÃO DE ACESSOS E SEGURANÇA

A partir da aplicação combinada do EDM01 e do APO01, este trabalho propõe um conjunto objetivo de regras para orientar a gestão de acessos e a segurança da informação na Fatec Barueri. As regras foram organizadas em quatro grupos.

6.1 Regras de ciclo de vida de identidade

- Toda conta de acesso deve ser criada automaticamente a partir da matrícula confirmada no SIGA, sem criação manual paralela.
- Toda conta deve ser desativada em, no máximo, 5 dias úteis após a formatura, o trancamento de matrícula ou o desligamento do vínculo com a instituição.
- É proibida a existência de contas genéricas ou compartilhadas para uso individual de alunos; contas de laboratório devem ser nominais, ainda que a máquina física seja compartilhada.

6.2 Regras de controle de acesso

- O acesso a recursos deve seguir o princípio do menor privilégio: cada perfil (aluno, professor, coordenador, técnico) recebe apenas as permissões estritamente necessárias às suas atividades (RBAC).
- Privilégios administrativos (Domain Admin, Schema Admin) só podem ser concedidos mediante aprovação formal do Comitê de Segurança da Informação e TI.
- Toda concessão de privilégio elevado deve ter prazo de validade definido, sujeito a renovação justificada.

6.3 Regras de autenticação e senha

- Uso obrigatório de autenticação multifator (MFA) para contas com privilégios administrativos e para acesso remoto a sistemas institucionais.
- Política de senha definida via GPO, com tamanho mínimo, uso de caracteres especiais e troca periódica.
- Bloqueio automático de estação após período de inatividade nos laboratórios, complementado por campanha de conscientização sobre o uso do atalho Win + L.

6.4 Regras de auditoria e resposta a incidentes

- Revisão trimestral obrigatória de todas as contas com privilégios elevados e das permissões de pastas de rede e laboratórios, com ata registrada pelo Comitê.
- Monitoramento contínuo de logs de autenticação (AD/SIEM) para identificar tentativas de força bruta, acessos simultâneos suspeitos e elevação indevida de privilégio.
- Todo incidente de segurança envolvendo identidade ou acesso deve ser registrado, analisado e reportado ao Comitê e, quando aplicável, ao Centro Paula Sousa.

7. CONCLUSÃO

Este trabalho demonstrou, de forma aplicada, como dois processos do COBIT um de governança (EDM01) e um de gestão (APO01) podem ser utilizados de maneira complementar para estruturar a segurança da informação e a gestão de acessos em uma instituição de ensino como a Fatec Barueri. A análise realizada permitiu compreender que a governança e a gestão de TI precisam atuar de forma integrada, de modo que as decisões institucionais sejam transformadas em práticas operacionais confiáveis, documentadas e repetíveis. Nesse sentido, o EDM01 estabelece as diretrizes e responsabilidades necessárias para a tomada de decisão, enquanto o APO01 contribui para organizar a execução dessas diretrizes no cotidiano da instituição.

O EDM01 permitiu construir a base de legitimidade das decisões: identificar quem deveria decidir sobre segurança e acesso, mapear as normas já existentes e propor uma estrutura de governança o Comitê de Segurança da Informação e TI capaz de definir diretrizes, aprovar exceções e monitorar a evolução da governança ao longo do tempo. A proposta também possibilita estabelecer de forma mais clara a responsabilidade dos diferentes envolvidos, incluindo a Direção, a Coordenação de TI, os responsáveis pela segurança da informação e os demais stakeholders institucionais, evitando que decisões relacionadas a acessos privilegiados e segurança dependam exclusivamente de ações técnicas isoladas. Além disso, o acompanhamento por meio de indicadores, relatórios e ciclos de revisão permite que a governança seja continuamente avaliada e ajustada diante de incidentes, mudanças institucionais ou alterações nas exigências legais.

Já o APO01 traduziu essa governança em prática operacional, detalhando processos de gestão do ciclo de vida de identidades, papéis técnicos e de negócio, atividades recorrentes de auditoria e monitoramento, documentação mínima necessária, políticas de senha e desligamento, e as competências que a equipe técnica precisa desenvolver. A aplicação do processo também estabelece uma organização mais clara das responsabilidades entre o Comitê de Segurança da Informação e TI, o responsável pela segurança da informação, o administrador de identidade e acessos e a equipe de suporte e Helpdesk. Dessa forma, atividades como criação e revogação de contas, revisão de privilégios, monitoramento de logs, backup do Active Directory e manutenção da infraestrutura passam a fazer parte de rotinas estruturadas, reduzindo a dependência de procedimentos informais e aumentando a capacidade de auditoria.

A principal contribuição do trabalho está em evidenciar que problemas comuns em laboratórios compartilhados como credenciais genéricas, contas órfãs e ausência de revisão de privilégios não são apenas falhas técnicas pontuais, mas sintomas de uma governança de TI ainda pouco formalizada. A aplicação estruturada do COBIT, mesmo restrita a dois processos, já indica um caminho consistente para reduzir esses riscos, aumentar a rastreabilidade de acessos e aproximar a Fatec Barueri das exigências da LGPD e das diretrizes do Centro Paula Sousa. As regras propostas reforçam essa contribuição ao estabelecer a criação de contas a partir da matrícula confirmada no SIGA, a desativação das contas após o encerramento do vínculo institucional, a proibição de contas genéricas para uso individual, a aplicação do princípio do menor privilégio, o uso de RBAC e MFA em situações definidas, além da realização de revisões periódicas e do monitoramento dos registros de autenticação.

Além disso, a proposta demonstra que a segurança da informação não deve ser tratada somente como uma responsabilidade da equipe técnica, mas como uma prática que envolve diferentes níveis da instituição. A definição de papéis, políticas, procedimentos, documentação e competências contribui para criar uma cultura de segurança mais consistente, na qual professores, alunos e profissionais de TI possuem responsabilidades relacionadas ao uso adequado dos recursos tecnológicos. Medidas como a conscientização sobre o não compartilhamento de senhas, o bloqueio das estações de trabalho e a capacitação da equipe técnica complementam os controles tecnológicos e ajudam a reduzir riscos associados ao comportamento dos usuários.

Como continuidade deste trabalho, sugere-se a extensão da análise a processos correlatos, como o APO13 (Gestão de Segurança) e o DSS05 (Gestão de Serviços de Segurança), bem como a validação prática das regras propostas junto à equipe de TI da unidade. Também se recomenda que, em uma futura etapa de implantação, sejam avaliados os mecanismos de integração entre o SIGA e o Active Directory / Entra ID, a automatização do ciclo de vida das identidades, a efetividade dos indicadores de governança e os procedimentos de resposta a incidentes. Dessa forma, a aplicação dos processos do COBIT poderá evoluir de uma proposta conceitual para um modelo efetivamente incorporado à rotina da Fatec Barueri, fortalecendo a segurança da informação, a rastreabilidade, a continuidade dos serviços e a conformidade institucional.

REFERÊNCIAS

ISACA. COBIT 2019 Framework: Introduction and Methodology. Schaumburg, IL: ISACA, 2018.

ISACA. COBIT 2019 Framework: Governance and Management Objectives. Schaumburg, IL: ISACA, 2018.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018.

BRASIL. Lei nº 12.527, de 18 de novembro de 2011. Lei de Acesso à Informação (LAI). Brasília, DF: Presidência da República, 2011.

CENTRO PAULA SOUSA. Estatuto do Centro Estadual de Educação Tecnológica Paula Souza. São Paulo: CPS, [s.d.].

Material de aula da disciplina de Gestão de TI, Fatec Barueri, ministrada pelo Professor Vander Ribeiro, 2026.